

JERUSALEM COLLEGE OF ENGINEERING

(AN AUTONOMOUS INSTITUTION) — DEPARTMENT OF AI & ML

MODEL QUESTION BANK ANSWER KEY —

REGULATION 2023

COURSE: JAL2007 — STORAGE TECHNOLOGIES | YEAR/SEM: III / V | CO: CO5

Unit No. & Title: Unit V — Securing Storage Infrastructure	Question No.: Part B Question 2
Cognitive Level: K4 (Analyze Level)	Maximum Marks: 16 Marks
Question Statement: Analyze the major storage security domains and examine the common threats associated with each domain to determine their impact on protecting a storage infrastructure.	

TABLE OF CONTENTS	PAGE
1. Introduction to Storage Security & The CIA Triad Goals	Page 1
2. Comprehensive Architecture of Storage Security Domains	Page 2
3. Deep-Dive Threat Analysis: Application, Host, & Network Domains	Page 3
4. Deep-Dive Threat Analysis: Storage System, Management, & Physical Domains	Page 4
5. Defense-in-Depth Security Controls & Multi-Domain Evaluation Matrix	Page 5
6. Domain Risk Profile Analysis, GRC Integration, & Summary	Page 6

1. INTRODUCTION TO STORAGE SECURITY & THE CIA TRIAD

In modern enterprise data centers, storage infrastructure represents the core repository for critical organizational assets, hosting transactional databases, proprietary intellectual property, employee records, and regulatory archives. Securing storage infrastructure requires a proactive defense mechanism that prevents unauthorized disclosure, malicious alteration, and unexpected downtime. Unlike conventional network security that focuses on perimeter defenses, **storage security** specifically safeguards data at rest, data in transit across storage networks, and administrative access paths.

The Information Security Goals (The CIA Triad):

Storage security frameworks are anchored around three fundamental pillars:

- **Confidentiality:** Ensures that sensitive data is accessible only to authorized users, processes, and applications. In a storage array, confidentiality prevents unauthorized entities from viewing confidential customer records, financial databases, or backup sets. Key implementations include payload encryption, multi-factor authentication (MFA), and strict access control lists (ACLs).
- **Integrity:** Guarantees that stored data remains accurate, complete, authentic, and protected against unauthorized modification or deletion. Unintended data alterations caused by silent bit rot, ransomware attacks, or insider tampering compromise integrity. Defensive controls include SHA-256 cryptographic hashing, write-once-read-many (WORM) storage, digital signatures, and automated block parity checks.
- **Availability:** Assures that authorized users have timely, uninterrupted, and reliable access to storage resources whenever required. Hardware disk failures, storage network cable disconnections, controller crashes, or Denial-of-Service (DoS) attacks degrade availability. Protections include RAID redundancy, dual-controller multipathing, active-active replication, and robust disaster recovery frameworks.

EXAM ANSWER NOTE: In university examinations, students must clearly define the CIA Triad within the context of storage systems (data at rest, data in motion, and management access) to secure full marks under Cognitive Level K4.

2. ARCHITECTURE OF STORAGE SECURITY DOMAINS

To effectively secure a complex enterprise data center, security architects divide the infrastructure into discrete logical and physical areas termed **Storage Security Domains**. A security domain encompasses a group of related components, protocols, and interfaces that share similar operational functions and threat exposure levels. Securing only physical disks or storage array controllers is insufficient; a compromise in any single domain can propagate horizontally and compromise the entire storage ecosystem.

The six major storage security domains recognized in enterprise architectures are:

Storage Security Domain	Domain Scope & Key Components	Primary Security Boundary
1. Application Domain	ERP systems, DBMS, web portals, analytics engines, custom business applications.	End-user authentication, API validation, SQL query sanitization.
2. Host Domain	Physical servers, virtual machine hypervisors (ESXi, KVM), OS kernel, HBA drivers, backup clients.	OS hardening, privilege separation, endpoint detection, driver security.
3. Network Domain	FC fabric, SAN switches, IP-SAN routers, iSCSI Ethernet switches, FCoE CNAs, ISL trunk lines.	Network segmentation, SAN zoning, VLAN isolation, link encryption.
4. Storage System Domain	Storage arrays, array controllers, disk enclosures, HDDs, SSDs, LUNs, RAID groups, cache memory.	LUN masking, self-encrypting drives (SED), cache vaulting, array ACLs.
5. Management Domain	Storage management consoles, REST APIs, CLI SSH interfaces, SNMP monitoring, Out-of-Band (OOB) networks.	Role-Based Access Control (RBAC), SSH keys, audit logging, MFA.
6. Physical Domain	Data center buildings, server racks, biometric doors, HVAC systems, power distribution (UPS/PDU), tape vaults.	Biometric access, CCTV surveillance, environmental sensors, physical locks.

Inter-Domain Data Flow & Threat Boundaries:

In a standard SAN or NAS deployment, data traverses multiple security domains sequentially. For example, when an application requests a database block:

1. The **Application Domain** processes the SQL user request and forwards an I/O query to the database engine.
2. The **Host Domain** translates the I/O request into SCSI commands via the operating system storage stack and Host Bus Adapter (HBA).
3. The **Network Domain** encapsulates SCSI commands into Fibre Channel frames or iSCSI TCP/IP packets and routes them across SAN switches.
4. The **Storage System Domain** receives frames via front-end ports, verifies LUN masking, searches controller cache, and writes data to physical disks.
5. Simultaneously, the **Management Domain** monitors array health via Out-of-Band IP networks, while the **Physical Domain** maintains hardware environmental stability.

A vulnerability exploited in any single domain—such as a compromised management password—allows an attacker to bypass protections in adjacent domains and gain unauthorized control over underlying storage media.

3. DEEP-DIVE THREAT ANALYSIS: APPLICATION, HOST, & NETWORK DOMAINS

An effective security evaluation requires identifying specific threat vectors, attack mechanisms, and their technical impacts across each domain.

3.1 Application Domain Threats

The application domain acts as the direct entry point for end-users and client applications accessing stored data. Primary security threats include:

- **SQL Injection (SQLi) & Unsanitized Input:** Attackers inject malicious SQL statements into input fields, tricking application servers into executing arbitrary database queries that bypass authentication, extract entire tables, or corrupt records.
- **Application Buffer Overflows & Remote Code Execution (RCE):** Vulnerabilities in application logic allow attackers to send oversized payloads, overwrite process memory, execute arbitrary code, and gain elevated control over connected storage volumes.
- **Unauthenticated API Access & Session Hijacking:** Weak session token management or unencrypted REST APIs allow malicious entities to intercept valid user sessions and issue unauthorized data read/write commands.
- **Malware Ingestion:** Applications accepting public file uploads without automated anti-virus screening can unwittingly write ransomware payloads directly onto shared storage repositories.

3.2 Host Domain Threats

Hosts (servers and hypervisors) execute operating systems and drivers that communicate directly with storage networks. Primary threats include:

- **OS & Hypervisor Kernel Exploits:** Unpatched vulnerabilities in Linux, Windows Server, or VMware ESXi hypervisors permit local privilege escalation, allowing attackers to escape virtual machine boundaries and compromise the host storage stack.
- **Ransomware & Host-Level Data Encryption:** Malicious software executing with administrator privileges scans attached mount points, local disks, and mapped SAN LUNs, systematically encrypting production files and demanding ransom.
- **Compromised HBA Drivers & WWPN Spoofing:** Attackers gaining root access on a host server can modify Host Bus Adapter driver configurations, forging legitimate World Wide Port Names (WWPNs) to hijack SAN storage volumes assigned to other servers.
- **Unauthorized Host Login & Credential Theft:** Weak SSH passwords or unmanaged service accounts allow unauthorized actors to log into backup servers and wipe catalog indexes or backup image files.

3.3 Network Domain Threats

The network domain transports storage commands and data blocks between hosts and storage arrays over Fibre Channel, iSCSI, or FCoE networks. Primary threats include:

- **Network Eavesdropping & Packet Sniffing:** Unencrypted iSCSI TCP/IP traffic or unencrypted FC Inter-Switch Links (ISLs) can be intercepted using packet analyzers, exposing sensitive clear-text data payloads in transit.
- **Man-in-the-Middle (MitM) & Session Spoofing:** Attackers inject rogue network devices into Ethernet/FC fabrics, spoofing iSCSI target IP addresses or FC switch fabric logins to intercept and alter data blocks during transport.
- **Unauthorized Switch Access & Fabric Spoofing:** Unsecured FC switch management ports allow unauthorized nodes to register with the Fibre Channel Name Server, disrupt fabric routing, or bypass switch zoning rules.
- **Denial-of-Service (DoS) Attacks:** Flooding SAN switch ports with malformed frames or excessive iSCSI login requests exhausts switch memory and link bandwidth, causing widespread storage disconnects.

4. DEEP-DIVE THREAT ANALYSIS: STORAGE SYSTEM, MANAGEMENT, & PHYSICAL DOMAINS

4.1 Storage System Domain Threats

The storage system domain includes storage arrays, RAID controllers, cache, and disk enclosures. Threats targeting this domain directly threaten data persistence:

- **LUN Spoofing & Unauthorized Masking Bypass:** If LUN masking rules on a storage array controller are misconfigured or manipulated, an unauthorized host can issue SCSI read/write commands to LUNs allocated to other mission-critical servers.
- **Array Controller Compromise & Firmware Tampering:** Flaws in storage controller microcode allow attackers to upload malicious firmware, bypass hardware encryption keys, disable cache mirroring, or cause catastrophic array failure.
- **Physical Drive Theft & Data Remanence:** Decommissioned or defective hard disks/SSDs discarded without cryptographic erasure (zeroization) can be scavenged by unauthorized parties to recover confidential remnant files.
- **Cache Corruption & Power Vaulting Failure:** Unscheduled data center power loss combined with degraded battery-backed cache modules results in unwritten dirty cache blocks being lost, causing filesystem corruption.

4.2 Management Domain Threats

The management domain provides administrative interfaces (GUI/CLI/REST API) used to configure storage systems. Threats to this domain carry severe enterprise impact:

- **Administrator Privilege Escalation & Account Takeover:** Compromising a storage administrator's credentials provides full control over storage management software, enabling malicious deletion of storage pools, snapshots, and backups.
- **Unencrypted Out-of-Band (OOB) Protocols:** Utilizing clear-text management protocols such as HTTP, Telnet, or unencrypted SNMP v1/v2 exposes administrative passwords to passive network monitoring.
- **Unauthenticated REST API Exploitation:** Modern Software-Defined Storage (SDS) platforms exposing automation APIs without strict mutual TLS (mTLS) or OAuth authentication allow unauthorized scripts to execute destructive provisioning commands.
- **Disabled Audit Logging & Log Tampering:** Attackers wipe or alter storage array event logs to conceal unauthorized configuration changes, preventing post-incident forensic investigation.

4.3 Physical Domain Threats

The physical domain covers physical buildings, computer rooms, server racks, and environmental controls housing storage equipment:

- **Unauthorized Facility Access & Hardware Theft:** Inadequate physical security (e.g., lack of biometric doors or security guards) allows unauthorized personnel to physically extract disk drives, tape cartridges, or entire server blades.
- **Environmental Hazards (HVAC, Fire, Water):** Air conditioning failures cause thermal throttling and drive head crashes. Automatic sprinkler system malfunctions or flooding permanently destroy magnetic platters and circuit boards.
- **Power Outages & Voltage Fluctuations:** Unstable grid power or failing Uninterruptible Power Supply (UPS) units cause sudden thermal collapse and incomplete disk writes across RAID enclosures.

5. DEFENSE-IN-DEPTH SECURITY CONTROLS & EVALUATION MATRIX

Protecting an enterprise storage infrastructure against multi-domain threats requires a **Defense-in-Depth** strategy. Implementing overlapping security controls ensures that if a vulnerability is exploited in one domain, controls in adjacent domains prevent a total breach.

Comprehensive 6-Domain Threat & Control Evaluation Matrix:

Domain	Key Threat Vectors	Security Impact	Recommended Defense Controls	Risk
Application	SQL Injection, RCE, Buffer Overflows, Malicious Uploads.	High: Data breach, database corruption, unauthorized access.	Parametric queries, input sanitization, Web Application Firewalls (WAF), API authentication.	CRITICAL
Host	OS/Hypervisor exploits, Ransomware, WWPN Spoofing, Malware.	High: Server takeover, encrypted filesystems, LUN hijacking.	OS hardening, Endpoint Detection (EDR), HBA driver signing, isolated backup agents.	HIGH
Network	Packet Sniffing, MitM, Rogue Switch Registration, DoS.	Medium-High: Data exposure in transit, fabric disruption.	FC Hardware Zoning, VLAN segmentation, IPsec / FC-SP link encryption, CHAP auth.	HIGH
Storage System	LUN Spoofing, Drive Theft, Controller Exploits, Data Remanence.	High: Loss of physical data confidentiality, array outage.	LUN Masking, Self-Encrypting Drives (SED), Cryptographic Erasure, Array ACLs.	HIGH
Management	Privilege Escalation, Unencrypted OOB Protocols, API Exploits.	Catastrophic: Mass LUN deletion, destroyed backups/snapshots.	Role-Based Access Control (RBAC), Multi-Factor Auth (MFA), HTTPS/SSH, Immutable Audit Logs.	CRITICAL
Physical	Media Theft, Unauthorized Entry, HVAC Failure, Water Damage.	Medium: Loss of media, thermal drive damage, power loss.	Biometric access, 24/7 CCTV, redundant UPS/generators, FM-200 gas fire suppression.	MEDIUM

Key Security Control Implementations Across Storage Architectures:

- **LUN Masking vs. Zoning:** Switch *Zoning* restricts communication between host HBAs and storage array ports at the SAN fabric layer (Network Domain). *LUN Masking* is implemented on storage array controllers (Storage System Domain) to restrict access to specific LUN IDs based on host WWPNS.
- **Self-Encrypting Drives (SED) & Key Management:** SEDs perform hardware-based AES-256 encryption at the drive controller level without CPU overhead. Centralized Key Management Servers (KMS) managing Key Encryption Keys (KEKs) ensure that stolen drives cannot be read when removed from enclosures.
- **Role-Based Access Control (RBAC) & Immutable Logging:** Restricts storage management privileges so storage operators cannot delete snapshots or modify audit logs, mitigating insider threats.

6. DOMAIN RISK PROFILES, GRC INTEGRATION, & CONCLUSION

To optimize security investments, enterprise security teams conduct quantitative risk assessments comparing threat likelihood against business impact across all six storage security domains.

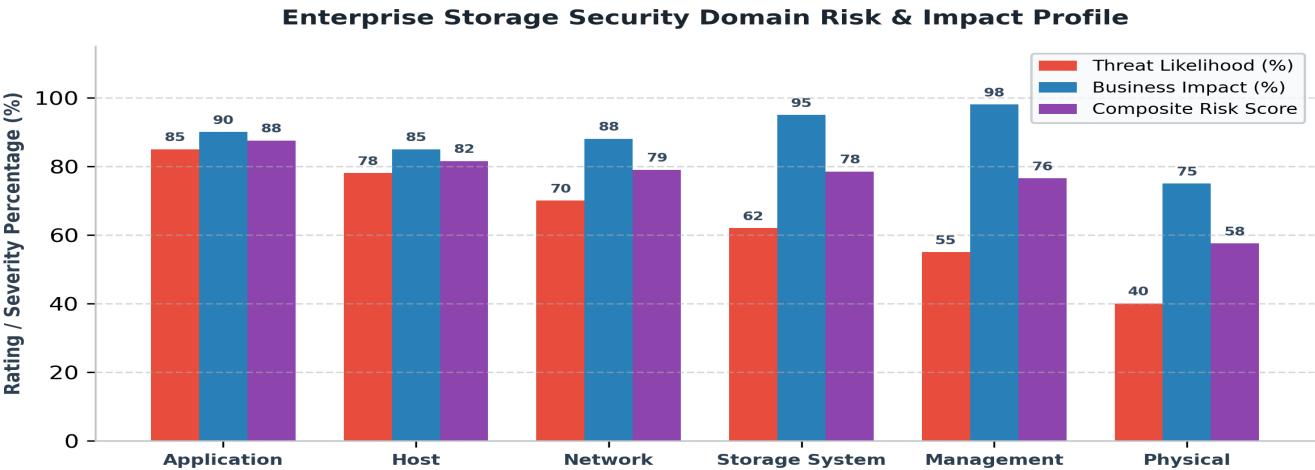


Figure 6.1: Enterprise Storage Security Domain Risk & Impact Profile Analysis.

6.1 Integration with Governance, Risk, and Compliance (GRC)

Storage security domains do not operate in isolation; they must align with organizational Governance, Risk, and Compliance (GRC) frameworks:

- **Governance:** Establishes enterprise storage policies defining data classification, backup retention intervals, access authorization workflows, and security oversight across all domains.
- **Risk Management:** Continuously identifies vulnerabilities across application, host, network, storage, management, and physical layers. It conducts qualitative/quantitative risk analysis and implements controls via Risk Avoidance, Mitigation, Transfer, or Acceptance.
- **Compliance:** Verifies that storage security controls fulfill legal and regulatory mandates such as ISO/IEC 27001, NIST SP 800-53, HIPAA (healthcare privacy), PCI DSS (payment card encryption), and GDPR (data erasure regulations).

6.2 Summary & Academic Conclusion

Conclusion: Comprehensive protection of an enterprise storage infrastructure demands a holistic, multi-layered approach spanning all six storage security domains—Application, Host, Network, Storage System, Management, and Physical. Securing only storage array controllers or physical facilities leaves critical attack vectors exposed at the application, host OS, or network transmission layers. By deploying robust Defense-in-Depth controls—including LUN masking, hardware fabric zoning, Self-Encrypting Drives (SED), encrypted management protocols (HTTPS/SSH), Role-Based Access Control (RBAC), and biometric physical security—organizations can systematically mitigate threats to maintaining data confidentiality, integrity, and availability (CIA Triad) across complex storage environments.

MODEL ANSWER SUMMARY: This completes the 16-mark model answer key for Unit V Part B Question 2. All 6 storage security domains, threat vectors, impacts, defense controls, evaluation matrix, and GRC alignment have been thoroughly analyzed.